

TRABAJO DE FIN DE CICLO

DR. AGRAMONTE

Plataforma web de gestión de citas médicas



Autora: Mar Agramonte Campos

Centro: CESUR

Ciclo: Desarrollo de Aplicaciones Multiplataforma

Tutores: Pascual Barrer – Jaume Rossinrol

Curso: 2025–2026

Fecha: Junio 2026

Resumen

Dr. Agramonte es una aplicación web para que pacientes reserven, consulten y cancelen citas médicas sin depender del teléfono del profesional. El sistema integra un frontend estático (HTML, CSS y JavaScript), una API REST con **Spring Boot 3.5.3**, base de datos **PostgreSQL**, autenticación **JWT**, control de concurrencia con **bloqueo pesimista**, notificaciones **Twilio** (SMS/WhatsApp) y despliegue reproducible con **Docker Compose**.

El proyecto nace de una observación directa del sector sanitario: buena parte de las llamadas que recibe un médico fuera de su horario no son urgencias clínicas, sino gestión de agenda. Digitalizar esa parte administrativa devuelve tiempo al profesional sin sustituir el trato humano donde de verdad hace falta. Sobre esa idea se construye una herramienta pensada para consultas pequeñas y médicos autónomos, que mantienen la titularidad de sus datos en lugar de depender de plataformas de terceros.

La interfaz replica la identidad visual del consultorio: paleta **teal** (#0F766E, #14B8A6), tipografías DM Sans / DM Serif Display, modo claro/oscuro y diseño responsive. La reserva se organiza en pasos (centro, calendario, hora, datos y confirmación) y puede iniciarse desde `servicios.html` con el tipo de consulta preseleccionado. Un **cuadro de mando** restringido por rol convierte los datos operativos en información de gestión (carga por médico, demanda por especialidad, tasa de cancelación) y la interfaz sigue las pautas de accesibilidad **WCAG 2.1 AA**.

La calidad se respalda con una batería de **pruebas automatizadas** (unitarias, de seguridad y de integración con Testcontainers) y con análisis de vulnerabilidades **OWASP dependency-check**. La principal conclusión es que la coherencia entre memoria, código y demostración es tan determinante como la propia funcionalidad: este documento describe la versión *real* del sistema a junio de 2026, distinguiendo lo entregado de lo planificado como evolución.

Palabras clave: citas médicas, aplicación web, Spring Boot, API REST, PostgreSQL, JWT, concurrencia, Twilio, Docker, PWA, accesibilidad.

Abstract

Dr. Agramonte is a web application that lets patients book, review and cancel medical appointments without depending on the practitioner's phone line. The system integrates a static frontend (HTML, CSS and JavaScript), a REST API built with **Spring Boot 3.5.3**, a **PostgreSQL** database, **JWT** authentication, concurrency control through **pessimistic locking**, **Twilio** notifications (SMS/WhatsApp) and reproducible deployment with **Docker Compose**.

The project stems from direct observation of the healthcare sector: many of the calls a doctor receives outside working hours are not clinical emergencies but scheduling tasks. Digitising that administrative layer gives time back to the professional without replacing human contact where it is truly needed. On this premise, the tool is designed for small practices and self-employed doctors, who retain ownership of their data instead of relying on third-party platforms.

The interface mirrors the practice's visual identity: a **teal** palette (#0F766E, #14B8A6), DM Sans / DM Serif Display typefaces, light/dark mode and responsive design. Booking is organised in steps (centre, calendar, time, details and confirmation) and can be started from `servicios.html` with the appointment type preselected. A role-restricted **management dashboard** turns operational data into business insight (workload per doctor, demand per specialty, cancellation rate), and the interface follows **WCAG 2.1 AA** accessibility guidelines.

Quality is backed by a suite of **automated tests** (unit, security and Testcontainers-based integration) and **OWASP dependency-check** vulnerability analysis. The main conclusion is that consistency between report, code and demonstration is as decisive as functionality itself: this document describes the *real* state of the system as of June 2026, distinguishing what has been delivered from what is planned as future work.

Keywords: medical appointments, web application, Spring Boot, REST API, PostgreSQL, JWT, concurrency, Twilio, Docker, PWA, accessibility.

Índice general

Resumen	1
Abstract	2
1 Justificación y contexto	5
1.1 De dónde viene este proyecto	5
1.2 La carga administrativa invisible	5
1.3 El coste oculto para el profesional	6
1.4 El hueco que existe en el mercado	6
1.5 Viabilidad económica (estimación)	7
1.6 Por qué y para qué	8
1.7 Marco legal aplicable	8
2 Objetivos	9
2.1 Objetivo general	9
2.2 Objetivos específicos (alineados con la implementación)	9
3 Desarrollo	11
3.1 Contextualización del sector	11
3.1.1 Descripción del sector profesional	11
3.1.2 Tipos de solución y dónde encaja el proyecto	11
3.1.3 Competencias del desarrollador DAM aplicadas	12
3.1.4 Riesgos laborales	13
3.1.5 Medidas preventivas	13
3.1.6 Equipos de protección y buenas prácticas (EPIs)	13
3.2 Desarrollo principal	13
3.2.1 Del boceto inicial a la implementación	14
3.2.2 Metodología de desarrollo	14
3.2.3 Arquitectura general	15
3.2.4 Organización del backend en capas y DTOs	16
3.2.5 Stack tecnológico	17
3.2.6 Justificación de las tecnologías	17
3.2.7 Modelo de datos	18

3.2.8 Persistencia relacional frente a NoSQL	19
3.2.9 Frontend y paleta visual	20
3.2.10 Autenticación JWT	20
3.2.11 Reserva y concurrencia	21
3.2.12 Reserva como invitado	22
3.2.13 API principal	23
3.2.14 Manejo centralizado de errores	23
3.2.15 Notificaciones Twilio	24
3.2.16 Implementación del frontend	24
3.2.17 Accesibilidad y usabilidad (WCAG)	26
3.2.18 Sincronización de citas: una sola fuente de verdad	28
3.2.19 Cuadro de mando de gestión (analítica)	28
3.2.20 Seguridad y RGPD	30
3.2.21 Despliegue	30
3.2.22 Sostenibilidad y eficiencia (green computing)	31
3.2.23 Planificación temporal	33
3.2.24 Pruebas y validación	33
4 Conclusiones	35
Agradecimientos	38
Bibliografía	39
Anexos	41

Capítulo 1:

Justificación y contexto

1.1 De dónde viene este proyecto

Me he criado rodeada de sanidad. La mayoría de mis familiares y amigos trabajan en el sector, así que lo que sé de esta profesión no viene de un libro: viene de haberla visto de cerca durante años. Y lo que he visto se repite con una regularidad que asusta: un médico no desconecta cuando cierra la consulta. El teléfono sigue sonando. En Navidad, en verano, en mitad de una cena, incluso en mitad de un viaje. Siempre hay alguien que llama, ya sea para confirmar una cita, preguntar por una receta o pedir un consejo que, sinceramente, podría esperar.

La mayoría de esas llamadas no son urgencias. Son gestiones que, con la herramienta adecuada, el paciente podría resolver por su cuenta. Lo que muchas veces se pasa por alto es que ese médico también tiene familia, también necesita estar en una cena sin el teléfono encima y también tiene derecho a un domingo sin interrupciones. La tecnología no lo soluciona todo, pero sí puede encargarse de la parte administrativa que hoy recae directamente sobre el profesional. De ahí nace este proyecto: no es una idea inventada, es algo que observé durante años. Si el paciente puede gestionar sus citas solo, el médico recupera tiempo. Es así de simple.

1.2 La carga administrativa invisible

El problema no es solo cuántas llamadas entran, es quién acaba cogiéndolas. En muchas consultas pequeñas, o en centros que van desbordados, no hay personal de administración, así que el médico termina haciendo también ese trabajo. Cada vez que descuelga el teléfono para confirmar una cita o resolver un trámite, deja a medias lo que estaba haciendo con el paciente que tiene delante.

Este proyecto no quiere sustituir el trato humano ni apartar al profesional

del teléfono. Hay momentos en los que quien llama está asustado, confuso o simplemente necesita que alguien lo escuche, y para eso no vale una aplicación. Lo que busco es que el médico no tenga que coger el teléfono cada vez que alguien llama para confirmar que su cita del jueves sigue siendo a las cinco, ni cada vez que un paciente aprovecha que tiene su número para preguntar una duda que podría esperar a la próxima consulta. Eso sí lo puede hacer un sistema, y liberar ese tiempo es, en el fondo, el objetivo de toda la plataforma.

1.3 El coste oculto para el profesional

Hay algo que casi nunca se dice en voz alta. Cuando el médico sale de la consulta por la tarde, no deja de ser médico: sigue pendiente. Si un paciente le llama a las diez de la noche porque le duele algo, coge el teléfono. Si alguien le escribe un domingo por la mañana, contesta. Y todas esas horas en las que está trabajando, aunque nadie lo llame trabajo, no las cobra: están fuera de su jornada, fuera de su sueldo y dentro de su vida.

Y hay algo más que tampoco suele mirarse: nadie pregunta si el médico está bien, si ha dormido, si ha comido, si lleva semanas arrastrando un cansancio que no se permite parar. Como su oficio es cuidar, damos por hecho que ya se cuida solo, y muchas veces no es así. Lo he visto en gente de mi familia y en amigos del sector: pasan el día entero escuchando lo que le duele a todo el mundo y llegan a casa sin margen para contar lo suyo. Por eso entiendo esta aplicación no solo como un gestor de citas, sino como una pequeña forma de devolver un respiro a alguien que llevaba mucho tiempo sin pedirlo.

1.4 El hueco que existe en el mercado

En España, si trabajas en un hospital grande tienes sistemas de cita online; si formas parte de una clínica privada importante, tienes acceso a plataformas como Doctoralia o Top Doctors. Pero si eres un médico independiente o ejerces en una consulta pequeña, lo más probable es que sigas gestionando las citas por teléfono y agenda de papel. Las soluciones existentes presentan carencias para ese perfil:

- **Comisiones y suscripciones** pensadas para grandes volúmenes, que no encajan con quien atiende a 40–50 pacientes a la semana.
- **Dependencia de terceros:** el médico deja de ser dueño de sus propios datos, que pasan a alojarse en servidores ajenos.

- **Personalización limitada:** no se adaptan con facilidad a una especialidad concreta ni al modo de trabajar de una consulta pequeña.

Existe un espacio entre ambas opciones donde caben muchos profesionales que necesitan una herramienta especializada, accesible y bajo su control. **Dr. Agramonte se diseña pensando precisamente en ese espacio.**

1.5 Viabilidad económica (estimación)

Como desarrolladora, una decisión técnica no se sostiene solo por ser elegante: tiene que tener sentido también en coste. Por eso conviene una estimación, con cifras aproximadas y a modo ilustrativo, de lo que aporta la herramienta frente a su coste.

Ahorro. Si la reserva, confirmación y cancelación autónomas evitan en torno a **4 horas semanales** de gestión telefónica, y se valora la hora de consulta privada en unos 50 €, el ahorro ronda los 200 € semanales, del orden de **10.000 € al año** en tiempo recuperado por el profesional.

Coste. El desarrollo es un coste *único* (este propio TFG), y la operación es deliberadamente barata gracias a las decisiones de arquitectura: un frontend estático sin dependencias, un único backend Java y una base de datos relacional caben de sobra en una VPS modesta (del orden de 10 €/mes). No hay comisiones por cita ni cuotas de plataforma de terceros.

Conclusión. Con estas cifras —que habría que afinar en un caso real— la inversión se amortiza en pocos meses. Más allá del número, la idea de fondo es que las decisiones de desarrollo (sin frameworks innecesarios, contenedores ligeros, una sola base de datos relacional) no solo simplifican el código: también hacen el sistema **sostenible** para una consulta pequeña.

Conviene situar el proyecto frente a las alternativas reales. Las grandes plataformas del sector privado (Doctoralia, Top Doctors) están pensadas para clínicas y hospitales con volúmenes altos: aportan visibilidad y un directorio de pacientes, pero a cambio el profesional depende de un intermediario, asume sus condiciones económicas y deja de ser dueño de sus propios datos. En el otro extremo, las herramientas genéricas de gestión (agendas o CRM no sanitarios) son más baratas, pero no entienden las particularidades de la sanidad: no contemplan historial clínico, no se ajustan a la normativa de conservación de datos de salud ni manejan roles propios de la práctica médica. Dr. Agramonte no compete con ninguno de los dos en su terreno; ocupa el hueco intermedio, ofreciendo a una consulta pequeña una solución propia, simple y conforme a la normativa,

sin comisiones por cita ni dependencia de un tercero.

1.6 Por qué y para qué

Por qué: las consultas pequeñas y los médicos autónomos carecen de una herramienta de reserva propia, simple y bajo su control. **Para qué:** ofrecer un canal de autoservicio 24/7 que descargue al profesional de la gestión telefónica y mejore la experiencia del paciente, manteniendo la titularidad de los datos en manos del propio consultorio.

1.7 Marco legal aplicable

Cualquier aplicación que gestione datos de salud en Europa está sujeta a un marco legal exigente, precisamente porque se trata de información sensible:

- **RGPD** (Reglamento (UE) 2016/679): los datos de salud son una categoría especial de datos, con un nivel de protección reforzado.
- **LOPDGDD** (Ley Orgánica 3/2018): la adaptación española del RGPD.
- **Ley 41/2002**, básica reguladora de la autonomía del paciente, que regula la documentación clínica y sus plazos de conservación.

Esto significa que no basta con que la aplicación funcione: tiene que funcionar de forma segura y conforme a la ley. La plataforma incorpora política de privacidad, consentimiento explícito en la reserva y minimización de datos (solo se piden los necesarios para gestionar la cita). Los datos son la intimidad de alguien que ha confiado en el sistema, y tratarlos con cuidado no es un extra: es la base.

Capítulo 2:

Objetivos

Los objetivos del proyecto se formularon con un criterio que ha guiado toda la memoria: que cada meta fuera **concreta, verificable y realmente alcanzable** dentro del alcance de un TFG. No se persigue prometer un producto enorme a medias, sino entregar un sistema más pequeño pero completo, coherente y demostrable.

2.1 Objetivo general

Desarrollar una aplicación web de gestión de citas médicas que permita al paciente reservar y cancelar de forma autónoma, reduciendo la dependencia del teléfono y devolviendo al profesional el control de su tiempo, sobre un backend seguro y un despliegue reproducible.

2.2 Objetivos específicos (alineados con la implementación)

Cada objetivo específico se corresponde con código real del repositorio y, cuando aplica, con una prueba que lo respalda. Esa trazabilidad entre objetivo, implementación y prueba es deliberada: evita el riesgo de prometer en la memoria lo que no existe en el sistema.

1. Modelar y persistir usuarios, médicos, horarios y citas en **PostgreSQL** con migraciones **Flyway** y perfiles `postgres/mysql`.
2. Implementar API REST con **Spring Boot**, autenticación **JWT** y roles `PACIENTE`, `MEDICO` y `ADMIN` en `SecurityConfig`.
3. Garantizar integridad de reservas con `SELECT FOR UPDATE` sobre horarios disponibles.

4. Construir frontend responsive, PWA, modo oscuro y flujo de reserva accesible (`reserva.js`, `api-client.js`).
5. Enviar notificaciones al médico y al paciente vía **Twilio**, con recordatorio programado 24 h antes (`CitaReminderScheduler`).
6. Desplegar con **Docker Compose** (nginx + backend + base de datos).
7. Validar la calidad con pruebas automatizadas y análisis de vulnerabilidades, y preparar la defensa con una demo reproducible.
8. Ofrecer un **cuadro de mando de gestión** (módulo SGE) con analítica agregada —carga por médico, demanda por especialidad, reparto por centro y tasa de cancelación— restringido a los roles MEDICO/ADMIN.

Estos ocho objetivos se retoman en el capítulo de conclusiones para comprobar, uno a uno, su grado de cumplimiento.

Capítulo 3:

Desarrollo

3.1 Contextualización del sector

3.1.1 Descripción del sector profesional

El ciclo de Desarrollo de Aplicaciones Multiplataforma (DAM) aporta competencias en desarrollo multiplataforma, bases de datos, programación de servicios, diseño de interfaces y despliegue. Este proyecto las aplica a un ámbito muy concreto: el sanitario privado, y dentro de él, a la gestión de agenda, la relación paciente–médico y la comunicación entre ambos.

El puesto de referencia para este TFG es el de *desarrollador/a de aplicaciones* que da soporte a un consultorio de medicina interna. Es un perfil mixto: por un lado, trabajo de oficina propio del desarrollo de software (análisis, programación, pruebas, documentación); por otro, la necesidad de entender la realidad de un entorno clínico, donde los datos que se manejan son sensibles, los usuarios tienen edades y niveles digitales muy distintos, y un error no es un simple *bug*, sino una persona afectada. Comprender ese sector —sus tiempos, sus prioridades y sus límites legales— es tan parte del trabajo como escribir el código, y de hecho condiciona casi todas las decisiones técnicas que aparecen más adelante en esta memoria.

3.1.2 Tipos de solución y dónde encaja el proyecto

Desde el punto de vista del desarrollo, una herramienta de gestión de citas puede abordarse de tres formas, cada una con sus compromisos:

- **SaaS** (software como servicio): el proveedor aloja la aplicación y el cliente paga una suscripción (Doctoralia, Top Doctors). Cómodo y siempre actualizado, pero con costes recurrentes, comisiones y los datos en manos de un

tercero.

- **A medida** (*open source* / propietario): la aplicación se desarrolla y se despliega en la infraestructura del propio profesional. Da control total, sin comisiones y permite personalizar, a cambio de requerir conocimiento técnico para mantenerla.
- **Herramientas genéricas** (agendas o CRM no sanitarios): baratas, pero ajenas a las particularidades de la sanidad (historial clínico, normativa de conservación, roles).

Dr. Agramonte se sitúa en el modelo *a medida*: una solución propia, sin comisiones, con los datos bajo control del consultorio y pensada para ser desplegable y mantenible por un perfil técnico.

3.1.3 Competencias del desarrollador DAM aplicadas

El proyecto no nace de un módulo concreto, sino de la integración de las competencias del ciclo, que es precisamente lo que se espera de un perfil de *desarrollo*:

- **Acceso a datos**: modelo relacional, JPA y transacciones (las tablas y el bloqueo de la reserva).
- **Programación de servicios y procesos**: la API REST, la seguridad y la tarea programada de recordatorios.
- **Desarrollo de interfaces**: el frontend accesible y la PWA.
- **Sistemas y despliegue**: contenedores Docker, nginx y perfiles de configuración.
- **Empresa e iniciativa emprendedora**: el análisis del hueco de mercado y la viabilidad económica.

Las salidas naturales de este perfil —desarrollo *backend*, *full-stack* o iniciación a *DevOps*— se ven reflejadas en las distintas capas que ha sido necesario construir para este sistema.

3.1.4 Riesgos laborales

- **Ergonómicos:** posturas prolongadas ante pantalla, fatiga visual y movimientos repetitivos al teclear, tanto en el puesto de desarrollo como en la consulta.
- **Psicosociales:** estrés por interrupciones y carga administrativa; la digitalización de citas reduce esa presión.
- **Seguridad de la información:** el tratamiento de datos de salud (categoría especial RGPD) implica riesgo de fuga o acceso indebido.
- **Medioambientales:** consumo energético de equipos y servidores; gestión responsable de residuos electrónicos (RAEE).

3.1.5 Medidas preventivas

- **Ergonomía:** silla regulable, pantalla a la altura de los ojos, regla 20-20-20 para la vista y pausas activas periódicas.
- **Organización:** la propia herramienta reduce el riesgo psicosocial al eliminar llamadas e interrupciones de agenda.
- **Protección de datos:** cifrado en tránsito (HTTPS), contraseñas con BCrypt, secretos en variables de entorno, control de accesos por rol y copias de seguridad de la base de datos.
- **Sostenibilidad:** despliegue en contenedores ligeros y apagado de servicios no usados.

3.1.6 Equipos de protección y buenas prácticas (EPIs)

En un puesto de desarrollo software los EPIs físicos son limitados, por lo que la prevención se apoya en **equipamiento ergonómico** (reposamuñecas, filtro de luz azul, iluminación adecuada) y, sobre todo, en **buenas prácticas de seguridad** como “EPI digital”: no commitear credenciales, principio de mínimo privilegio, actualización de dependencias y revisión de vulnerabilidades.

3.2 Desarrollo principal

3.2.1 Del boceto inicial a la implementación

Antes de escribir una sola línea de código dibujé cómo debía sentirse la plataforma. El boceto inicial (figura 3.1) fijó las decisiones de fondo que luego se mantuvieron: un flujo de reserva guiado paso a paso, una estética sobria propia de un consultorio y una navegación pensada para que una persona mayor o poco habituada a la tecnología no se pierda. Ese boceto no fue un trámite: marcó la diferencia entre construir “una web de citas” y construir *esta* web de citas, con su identidad y su tono.

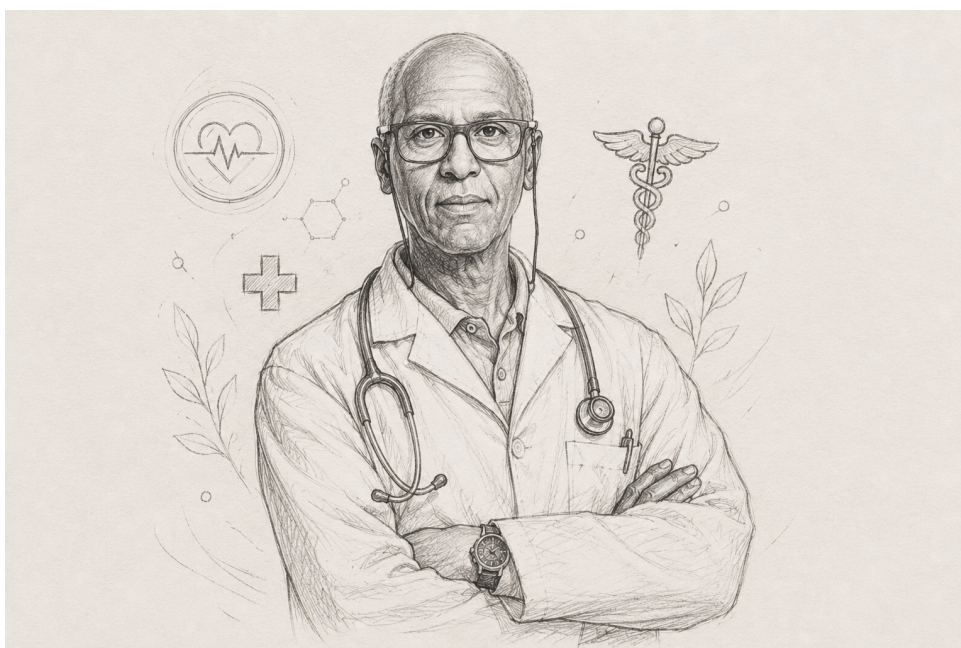


Figura 3.1: Boceto inicial de la plataforma: mapa de secciones y primeras ideas de interfaz.

Comparando el boceto con el resultado final se aprecia que las ideas centrales sobrevivieron al desarrollo (reserva por pasos, selección de centro, identidad visual del consultorio), mientras que otras se ajustaron a lo que el alcance de un TFG permite construir con garantías. Documentar esa evolución es parte del valor del proyecto: enseña no solo qué se hizo, sino por qué se decidió así.

3.2.2 Metodología de desarrollo

El proyecto no se construyó de una vez, sino de forma **iterativa e incremental**: primero una web estática que validaba la idea y la navegación, después el backend y la base de datos, luego la integración real entre frontend y API, y por último las notificaciones, la robustez para la demo y la documentación. Cada iteración partía de algo que ya funcionaba y le añadía una capa, lo que permitió

detectar pronto los problemas reales —como la incoherencia entre las citas del navegador y las de la base de datos— en lugar de descubrirlos al final.

Todo el código se gestionó con **control de versiones Git**, lo que aportó un historial de cambios, la posibilidad de volver atrás ante un error y una separación clara entre lo que es código fuente y lo que son secretos o configuración local (estos últimos excluidos del repositorio mediante `.gitignore`). Se trabajó además con la distinción entre **entornos**: una configuración para desarrollo y otra preparada para producción, seleccionables por perfiles, de modo que la misma base de código se comporta de forma adecuada en cada contexto sin tocar el código. Esta forma de trabajar es, en sí misma, una de las competencias que el ciclo busca consolidar.

3.2.3 Arquitectura general

La solución sigue una arquitectura en capas desplegada con contenedores, de forma que cada pieza tiene una responsabilidad clara y puede sustituirse o escalarse sin arrastrar a las demás. El navegador consume el frontend (HTML, CSS y JavaScript) servido por **nginx**; las peticiones a `/api` se redirigen mediante proxy inverso al backend Java, lo que evita problemas de CORS en producción y permite presentar todo bajo un mismo origen. El backend de **Spring Boot** concentra la lógica de negocio, la seguridad y el acceso a datos sobre **PostgreSQL**, y delega en **Twilio** (servicio externo invocado desde `TwilioMessageService`) el envío de SMS y mensajes de WhatsApp. Esta separación en capas (presentación, API, persistencia y servicios externos) es la que sostiene el resto de decisiones técnicas de la memoria.

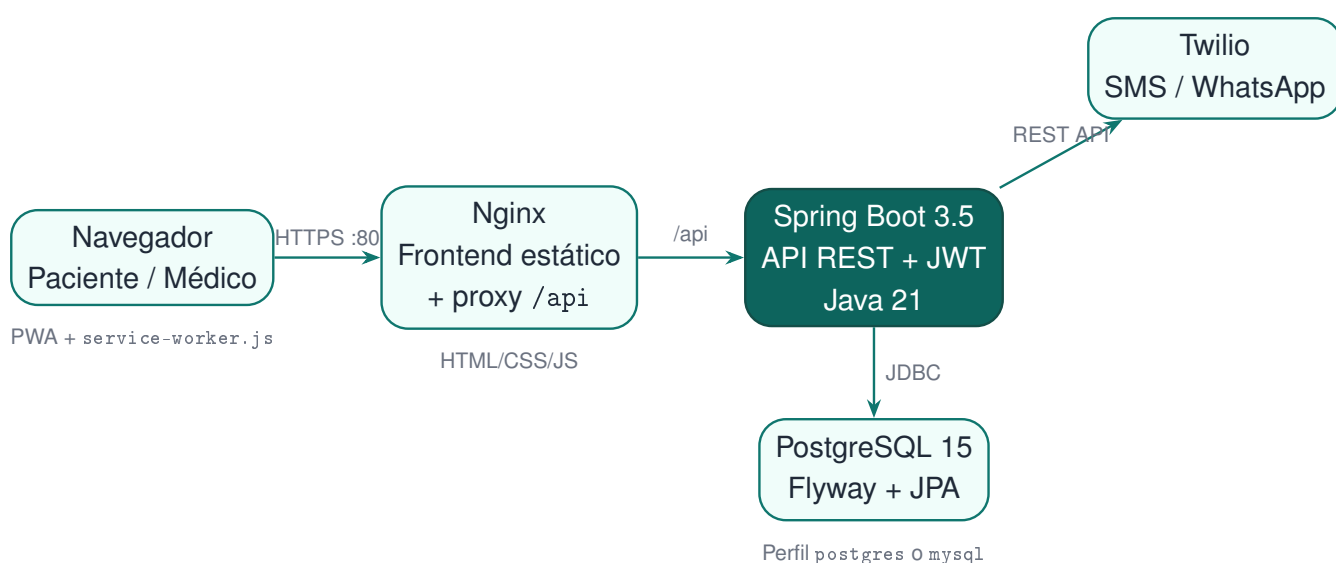


Figura 3.2: Arquitectura desplegada con Docker Compose (implementación actual)

3.2.4 Organización del backend en capas y DTOs

Dentro del backend, el código sigue el patrón clásico de **tres capas** de Spring, con responsabilidades bien separadas:

- **Controladores** (`controller`): reciben las peticiones HTTP, validan la entrada y devuelven la respuesta. No contienen lógica de negocio; solo orquestan. Ejemplos: `AuthController`, `CitaController`, `MedicoController`, `DisponibilidadController`.
- **Servicios** (`service`): concentran las reglas de negocio (crear una cita, comprobar disponibilidad, decidir si una cancelación es legítima) y abren las transacciones.
- **Repositorios** (`repository`): acceden a la base de datos mediante Spring Data JPA, incluida la consulta con bloqueo pesimista para la reserva.

Una decisión importante fue **no exponer nunca las entidades JPA directamente** en la API. Las respuestas usan objetos de transferencia de datos (*DTO*) como `CitaResponse` o `ReservaPublicaResponse`, y las peticiones se modelan con clases como `CrearCitaRequest` o `ReservaPublicaRequest`. Esto tiene tres ventajas: evita filtrar al exterior campos internos o sensibles, desacopla el modelo de base de datos del contrato público de la API (se puede cambiar la entidad sin romper a los clientes) y permite validar la entrada de forma declarativa con anotaciones. Es una práctica que el tribunal reconoce de inmediato como código profesional, no de juguete.

3.2.5 Stack tecnológico

Tabla 3.1: Componentes implementados

Capa	
Frontend	HTML5, CSS3, JS UI, PWA, <code>reserva.js</code> ES6+
Proxy / estatico	nginx (Docker) Archivos + proxy /api
Backend	Java 21, Spring Boot API, seguridad, negocio 3.5.3
Persistencia	PostgreSQL 15, Flyway, JPA Datos transaccionales
Notificaciones	Twilio API (Java SDK) SMS / WhatsApp
Despliegue	Docker Compose Entorno reproducible
Analítica	Chart.js 4 (vendoriza- Cuadro de mando de gestión do)

3.2.6 Justificación de las tecnologías

Cada pieza del stack se eligió por una razón concreta, no por moda:

- **Java + Spring Boot.** El tipado fuerte de Java detecta en tiempo de compilación errores que en un lenguaje dinámico aparecerían en producción, algo especialmente valioso cuando se manejan datos de salud. Spring Boot aporta, además, un ecosistema maduro: Spring Security como estándar de facto para autenticación y autorización, Spring Data JPA para el acceso a datos y transacciones ACID que garantizan que una reserva se complete entera o no se complete en absoluto.
- **PostgreSQL.** Para datos críticos (usuarios, médicos, horarios y citas) hace falta integridad referencial real, transacciones fiables y bloqueo a nivel de fila. PostgreSQL ofrece las tres cosas y permite implementar el control de concurrencia con `SELECT ... FOR UPDATE`, núcleo de la garantía de “no doble reserva”.
- **Flyway.** Versiona el esquema en migraciones numeradas (V1 a V6), de modo que cualquier entorno —el de desarrollo, el del tribunal o uno futuro en producción— se reconstruye exactamente igual al arrancar.

- **Twilio.** En lugar de montar infraestructura propia de mensajería, se delega el envío de SMS y WhatsApp en un proveedor consolidado, invocado directamente desde el backend Java.
- **Docker Compose.** Levanta todo el sistema con un único comando, eliminando el clásico “en mi máquina funciona”.

3.2.7 Modelo de datos

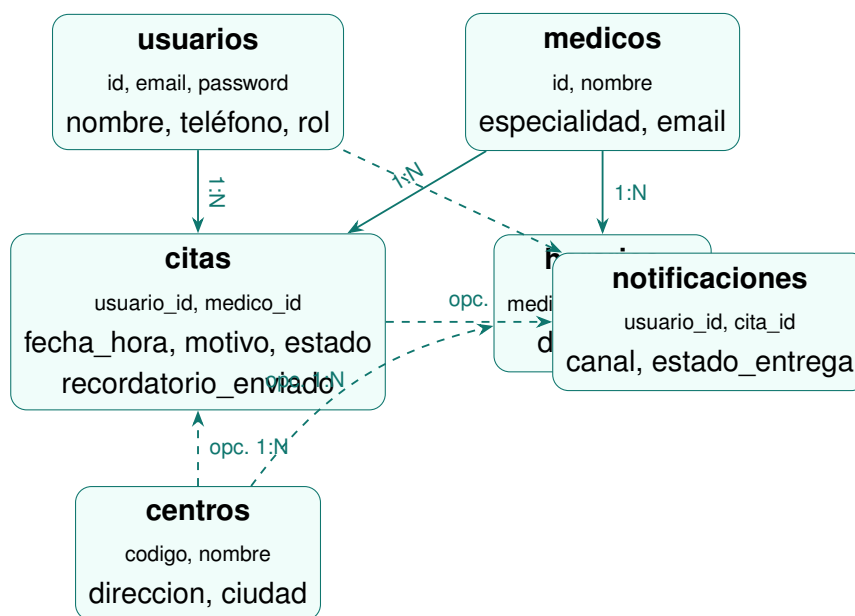


Figura 3.3: Modelo entidad-relación principal (PostgreSQL, migraciones Flyway V1–V6)

El modelo relacional gira en torno a cuatro entidades centrales —usuarios, medicos, horarios y citas— más notificaciones para el registro de avisos. Un usuario (paciente) puede tener muchas citas; un medico tiene muchos horarios y muchas citas; cada cita enlaza un usuario con un médico en una fecha y hora concretas. Cada tabla cumple un papel preciso:

- **usuarios:** identidad y credenciales (email único, contraseña cifrada, nombre, teléfono, rol). El campo `rol` discrimina entre PACIENTE, MEDICO y ADMIN, y `cuenta_invitada` marca las cuentas creadas en una reserva sin registro.
- **medicos:** datos profesionales (nombre, especialidad, email de contacto del facultativo).
- **horarios:** la disponibilidad real, como franjas con `inicio`, `fin`, un indicador disponible y el centro donde se atiende (`centro_id`, V6). Un índice úni-

co sobre (`medico_id`, `inicio`) impide crear dos franjas idénticas para el mismo médico.

- `citas`: las reservas, que vinculan `usuario_id` y `medico_id` con `fecha_hora`, `motivo` y `estado`. La cancelación no borra la fila: cambia su estado (mediante el enumerado `EstadoCita`), preservando la trazabilidad.
- `notificaciones`: el registro auditable de los avisos enviados, con su canal y estado de entrega.
- `centros`: los centros o consultas donde se atiende (`codigo` único, `nombre`, `dirección`, `ciudad`). Cada `cita` referencia opcionalmente su centro mediante `centro_id`.

La evolución del esquema queda reflejada en las migraciones Flyway: la `V2__cita_recordatorio` añade el campo `recordatorio_enviado` para evitar duplicar avisos Twilio, la `V3` extiende los horarios y crea el usuario médico de prueba, la `V4` introduce `cuenta_invitada` para la reserva sin registro previo, la `V5` crea la tabla `centros` (con sus datos iniciales) y añade `centro_id` a `citas`, y la `V6` añade `centro_id` a `horarios` (repartiendo la agenda por centro). Versionar el esquema de esta forma garantiza que la base de datos del tribunal se construya exactamente igual que la de desarrollo.

3.2.8 Persistencia relacional frente a NoSQL

La elección de la base de datos no fue automática: se valoró expresamente un enfoque **NoSQL documental** (MongoDB) frente al **relacional** (PostgreSQL) antes de decidir. Ambos paradigmas son válidos, pero resuelven problemas distintos, y conviene justificar por qué uno encaja mejor en este caso.

Una base de datos documental como MongoDB brilla cuando los datos son heterogéneos y poco estructurados, cuando el esquema cambia con frecuencia y cuando se prioriza la escalabilidad horizontal sobre la consistencia inmediata; guarda documentos JSON flexibles y evita las uniones (*joins*). Una base relacional, en cambio, destaca cuando los datos están fuertemente interrelacionados, cuando la integridad referencial y las transacciones **ACID** son innegociables y cuando hace falta bloqueo a nivel de fila.

En este proyecto los datos son intrínsecamente relacionales —un usuario reserva con un médico en un horario de un centro, generando una cita— y la invariante crítica del sistema es que **dos pacientes no reserven la misma franja**. Garantizar eso exige una transacción con bloqueo (`SELECT ...FOR UPDATE`),

justo donde el modelo relacional es más fuerte y el documental obligaría a soluciones más artificiales. Además, el volumen de una consulta médica es modesto, de modo que la escalabilidad horizontal de NoSQL no aporta una ventaja real aquí. Por todo ello, PostgreSQL es la opción correcta para el *núcleo transaccional*.

Esto no descarta NoSQL: simplemente lo reserva para donde sí encaja. El **historial clínico** es el candidato natural a un almacén documental, porque cada especialidad registra campos distintos (no hay un esquema único razonable) y los datos se añaden más que se modifican; lo mismo aplicaría a un *registro de auditoría* de accesos. La evolución coherente del sistema sería, por tanto, una **persistencia políglota**: PostgreSQL para el núcleo de citas (consistencia) y MongoDB para el historial clínico (flexibilidad), una línea ya recogida entre los trabajos futuros. La decisión, en resumen, no fue “relacional porque sí”, sino elegir la herramienta adecuada para cada tipo de dato.

3.2.9 Frontend y paleta visual

Los colores del documento y de los diagramas coinciden con `dr-agramonte.css`: teal principal, fondos `off-white`, tarjetas blancas y variante oscura (`data-theme="dark"`, fondo `#0F172A`).

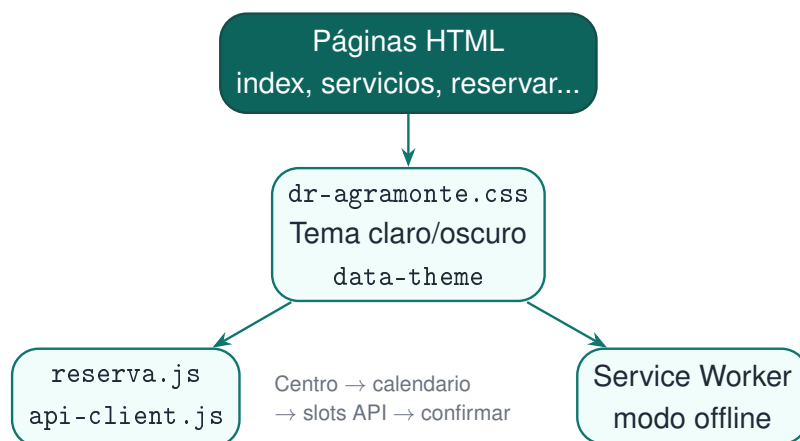


Figura 3.4: Capas del frontend y flujo de reserva en cuatro pasos

3.2.10 Autenticación JWT

La autenticación se resuelve con **JSON Web Tokens** en modo *stateless*: el servidor no guarda sesiones en base de datos, sino que confía en un token firmado que el cliente presenta en cada petición. `AuthController` expone `POST /api/auth/login` y `POST /api/auth/registro`; al autenticarse correctamente, `JwtProvider` genera un token firmado con clave secreta (algoritmo HMAC-SHA)

que incluye el identificador del usuario y una fecha de expiración. A partir de ahí, el token viaja en la cabecera `Authorization: Bearer` y `JwtAuthFilter` lo valida en cada petición protegida antes de que esta llegue al controlador.

Elegí este modelo por tres motivos concretos. Primero, **rendimiento**: al no consultar sesiones en BD, cada validación es una comprobación de firma en memoria. Segundo, **escalabilidad horizontal**: varios contenedores del backend pueden validar el mismo token sin compartir estado entre ellos. Tercero, **simplicidad de integración**: cualquier cliente (la web actual o, en el futuro, una app móvil) consume la API igual. La contrapartida honesta es que un token *stateless* no se puede revocar antes de que caduque; por eso la duración es corta y la introducción de un *refresh token* queda recogida como mejora futura. Las contraseñas nunca se almacenan en claro: se cifran con `BCryptPasswordEncoder` con factor de coste 12, de modo que incluso ante una fuga de la base de datos los hashes resultan costosísimos de revertir.

3.2.11 Reserva y concurrencia

El problema más interesante de toda la aplicación es aparentemente trivial: ¿qué pasa si dos pacientes intentan reservar la misma franja en el mismo instante? Sin control, ambos verían el hueco como libre, ambos confirmarían y el médico acabaría con dos personas citadas a la misma hora. Esto no es una hipótesis de laboratorio: en una agenda real ocurre justo en las franjas más demandadas. La solución no puede ser “cruzar los dedos”, tiene que ser determinista.

La estrategia elegida es el **bloqueo pesimista** a nivel de base de datos. Cuando llega una reserva, el repositorio recupera el horario con un `SELECT ...FOR UPDATE`, que bloquea esa fila concreta hasta que termina la transacción:

```
1 Horario horario = horarioRepository
2   .findByMedicoIdAndInicioAndDisponibleTrueForUpdate(...)
3   .orElseThrow(...);
```

Tras validar, se crea la `Cita`, se marca el horario no disponible y se invoca `CitaNotificationService`. El control de concurrencia es **bloqueo pesimista** (`SELECT ...FOR UPDATE` sobre `Horario`): si dos pacientes reservan la misma franja, una operación gana y la otra recibe **409 Conflict**, de forma determinista y sin reintentos.

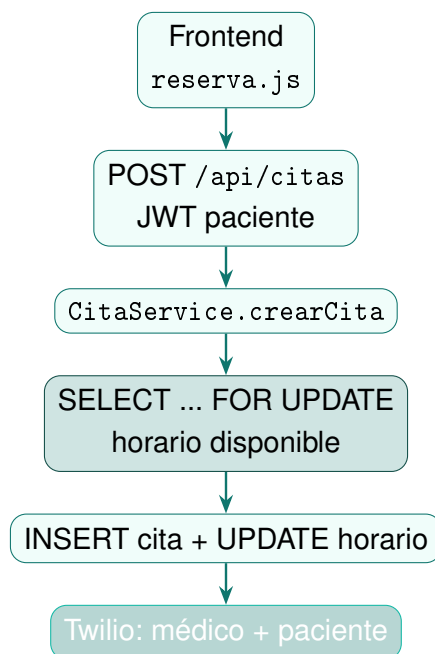


Figura 3.5: Flujo de reserva de cita con bloqueo pesimista y notificaciones

3.2.12 Reserva como invitado

No todos los pacientes quieren —o saben— crearse una cuenta antes de pedir cita, y obligar a registrarse es una de las principales causas de abandono en cualquier formulario. Por eso la plataforma ofrece **dos vías de reserva que persisten en la misma tabla** citas:

- **Paciente autenticado:** POST /api/citas con su token JWT.
- **Reserva pública (invitado):** POST /api/citas/reserva-publica, sin login previo.

En la reserva de invitado, el backend crea o reutiliza una cuenta de paciente marcada como `cuenta_invitada` (introducida en la migración Flyway V4); la contraseña es opcional, de modo que el invitado puede “ascender” más adelante a cuenta completa sin perder su historial de citas. Si el email ya pertenece a una cuenta con contraseña, el sistema responde con **HTTP 409** invitando a iniciar sesión, evitando que un tercero reserve en nombre de un usuario registrado. El invitado consulta y cancela sus citas mediante su email (GET /api/citas/por-email y DELETE /api/citas/publica/{id}).

Es importante presentarlo con honestidad: este mecanismo es **adecuado para un prototipo de TFG**, pero en producción la consulta y cancelación por email deberían reforzarse con un enlace firmado, un código de un solo uso (OTP)

o login obligatorio, para impedir que alguien acceda a las citas de otra persona conociendo solo su dirección de correo. Reconocer esa limitación forma parte del rigor del proyecto.

3.2.13 API principal

Método	Ruta	Descripción
POST	/api/auth/login, /registro	Sesión JWT
GET	/api/medicos	Listado de especialistas
GET	/api/centros	Listado de centros / consultas
GET	/api/disponibilidad	Slots por médico, fecha y centro
POST	/api/citas	Crear cita (paciente autenticado)
POST	/api/citas/reserva-publica	Reserva sin login (cuenta invitada)
GET	/api/citas/mias	Citas del paciente (JWT)
GET	/api/citas/por-email	Citas del invitado por email
DELETE	/api/citas/{id}	Cancelación (paciente autenticado)
GET	/api/estadisticas	Cuadro de mando de gestión (rol MEDICO/ADMIN)
POST	/api/contact	Formulario de contacto

Tabla 3.2: Endpoints principales

3.2.14 Manejo centralizado de errores

Una API es tan buena como sus errores: si cada fallo se devuelve de una forma distinta, el frontend se vuelve frágil y difícil de mantener. Para evitarlo, el backend usa un `GlobalExceptionHandler` que captura las excepciones de forma centralizada y las traduce a respuestas JSON consistentes, con su código HTTP adecuado. Así, una franja ya ocupada devuelve siempre **409 Conflict**, una acción sin permiso **403 Forbidden** y un recurso inexistente **404 Not Found**, todos con el mismo formato (marca de tiempo, estado, mensaje y ruta).

La ventaja es doble. Por un lado, el frontend puede confiar en una estructura de error predecible y mostrar mensajes claros al usuario (por ejemplo, “esa hora acaba de ocuparse, elige otra” ante un 409). Por otro, se evita filtrar trazas internas o detalles de implementación al exterior, lo que también es una cuestión de seguridad. Centralizar el manejo de errores en un único punto, en lugar de repetir bloques `try-catch` por todos los controladores, mantiene el código limpio y coherente.

3.2.15 Notificaciones Twilio

Las notificaciones son la otra mitad de la promesa del proyecto: si la web evita llamadas, tiene que avisar de forma fiable de lo que ocurre con cada cita. El envío se realiza **directamente desde el backend Java** mediante el SDK de Twilio, sin un servicio intermedio de colas. Es una arquitectura más simple y perfectamente adecuada al volumen de una consulta; un sistema de mensajería asíncrona con reintentos desacoplados sería justificable a mayor escala y se contempla como evolución futura. `CitaNotificationService` envía:

- Aviso al médico (`TWILIO_NOTIFY_TO`) en alta y cancelación.
- Confirmación y cancelación al paciente si tiene teléfono.
- Recordatorio ~24 h antes vía `@Scheduled` (ventana 23–25 h).

Variables: `TWILIO_ENABLED`, `TWILIO_ACCOUNT_SID`, `TWILIO_AUTH_TOKEN`, `TWILIO_FROM`, `TWILIO_CHANNEL` (whatsapp o sms).

3.2.16 Implementación del frontend

El frontend se construyó con HTML5, CSS3 y JavaScript nativo, sin frameworks como React o Vue. No fue la primera idea: al principio valoré usar React o incluso Python en el cliente, en parte por mi formación y por el *feedback* de profesionales del sector (OmniAccess). Sin embargo, tras un análisis de necesidades reales del proyecto, decidí prescindir de esa maquinaria. Fue una decisión consciente de ingeniería: la aplicación no maneja un estado global tan complejo como para justificarla, y evitarla reduce dependencias, acelera la carga inicial y permite que cualquier persona lea y modifique el código sin aprender antes una librería ni arrastrar un `node_modules` de cientos de megas. El JavaScript se organiza en módulos reutilizables (`api-client.js` para las llamadas REST con JWT, y la lógica de reserva en `reserva.js`), lo que evita duplicar código entre páginas. Saber *cuándo no* añadir una tecnología es, para un perfil de desarrollo, tan importante como saber usarla.

- **Reserva:** `reservar.html` + `reserva.js` (centros, calendario, franjas desde la API y *fallback* local).
- **Servicios:** los enlaces `reservar.html?servicio=...` preconfiguran tipo de consulta y motivo.
- **Tema:** botón luna/sol con preferencia recordada, y clase `btn-reserva` unificada en todo el sitio.

- **PWA:** `manifest.json` y `service-worker.js`; página `offline.html` para cuando no hay conexión.

Aplicación web progresiva (PWA). La web es instalable en el móvil como si fuera una app, sin pasar por una tienda de aplicaciones. Esto se logra con tres piezas: un `manifest.json` que define nombre, iconos y color de tema; un *service worker* que cachea los recursos críticos para que la navegación siga funcionando aunque la conexión falle, mostrando una página `offline.html` cuando no hay red; y el requisito de servir bajo HTTPS en producción. Para un paciente, la diferencia práctica es poder tener “Dr. Agramonte” como un icono más en su pantalla de inicio, reforzando justamente la idea de un canal propio y cercano al consultorio.

Selección de centro (multi-ubicación). El flujo de reserva permite elegir entre dos centros antes de fijar la hora: *Clínica Salamanca* (Madrid) y *Consulta Palma de Mallorca*, cada uno con sus propios días de atención. Esto refleja una realidad habitual: un mismo profesional atiende en más de una ubicación. El centro **se persiste en la base de datos**: existe una entidad `Centro` (tabla `centros`, creada en la migración Flyway V5) con un `codigo` estable —`madrid`, `palma`— que coincide con el identificador que ya empleaba el frontend, de modo que no hubo que reescribir la web. El backend expone el listado mediante `GET /api/centros`.

Agenda del médico por centro. La multi-ubicación se llevó hasta el final: cada `horario` pertenece a un centro (columna `centro_id`, migración V6), repartiendo la agenda del médico por día de la semana —Madrid los lunes, martes y jueves; Palma los miércoles, viernes y sábados— de forma que cada día el profesional está en un único sitio. A partir de ahí, todo encaja de manera coherente:

- La **disponibilidad se filtra por centro**: `GET /api/disponibilidad?medicoId=&fecha=¢roId=` solo devuelve los huecos de ese centro (un miércoles no ofrece horas de Madrid).
- La **cita hereda el centro de su horario**: al reservar, el centro no se deduce de lo que diga el cliente, sino de la franja realmente reservada, lo que evita incoherencias.
- La **agenda del médico muestra el centro** de cada cita y puede filtrarse por ubicación.

Todas las relaciones con `centro` son *nullable* a propósito: las citas y horarios anteriores a esta funcionalidad siguen siendo válidos.

Reserva guiada por pasos. La experiencia se divide en pasos pequeños (centro → calendario → hora → datos → confirmación) para reducir la carga cognitiva y no abrumar al usuario con todos los campos a la vez. Esta decisión, heredada del boceto inicial, es especialmente importante para pacientes mayores o poco habituados a la tecnología.

Accesibilidad. La interfaz cuida el uso de etiquetas HTML semánticas, atributos ARIA, un orden de tabulación lógico para navegar solo con teclado y un contraste de color suficiente entre texto y fondo, tanto en modo claro como oscuro. La accesibilidad no se entendió como un requisito formal, sino como la diferencia entre que una persona mayor pueda usar la aplicación o no. Por su importancia en un contexto sanitario, se detalla en su propia sección a continuación.

Validación de datos. La entrada del usuario se valida en dos niveles, porque ninguno de los dos basta por sí solo. En el **frontend** se comprueban formato de email, teléfono español y campos obligatorios antes de enviar, dando un aviso inmediato y evitando viajes innecesarios al servidor; esto mejora la experiencia, pero no es una garantía de seguridad porque puede manipularse. Por eso la validación se repite en el **backend** con las anotaciones de *Bean Validation* sobre los DTO de entrada: el servidor nunca confía en que el cliente haya validado bien. Esta doble barrera —comodidad en el cliente, seguridad en el servidor— es un principio básico de cualquier aplicación web seria.

3.2.17 Accesibilidad y usabilidad (WCAG)

En una aplicación de salud, la accesibilidad no es un extra: una parte importante de los pacientes son personas mayores o con dificultades visuales o motrices, y si no pueden usar la herramienta, esta sencillamente no cumple su función. Por eso la interfaz se diseñó tomando como referencia las **Pautas de Accesibilidad para el Contenido Web (WCAG 2.1)** en su nivel **AA**, organizadas en torno a sus cuatro principios: perceptible, operable, comprensible y robusto.

Perceptible: contraste de color verificado. El contraste entre texto y fondo se comprobó con la fórmula de luminancia relativa de la WCAG, no a ojo. El texto principal y los elementos interactivos superan con holgura el umbral AA de 4,5:1 para texto normal. Durante la revisión se detectó que el gris más claro usado para textos secundarios se quedaba en 2,5:1 (no cumplía) y se oscureció hasta cumplir, manteniendo en el modo oscuro un tono claro que conserva el contraste sobre fondo oscuro. La tabla siguiente recoge las medidas reales tras el ajuste:

Tabla 3.3: Ratios de contraste medidos (modo claro, sobre fondo blanco)

Uso	Ratio	WCAG AA
Texto principal (gris oscuro)	14,7:1	✓
Botones (blanco sobre teal)	5,5:1	✓
Enlaces y acentos (teal)	5,5:1	✓
Texto secundario (gris medio)	4,8:1	✓
Texto auxiliar / hints (ajustado)	4,6:1	✓
Mensajes de error (rojo)	4,8:1	✓

Operable: teclado y navegación. Toda la aplicación se puede manejar solo con teclado, con un orden de tabulación lógico y un **foco visible** reforzado (un contorno claro con `:focus-visible` de 2px sobre cada elemento al recibir el foco). Se añadió además un **enlace para saltar al contenido** (“Ir al contenido principal”), oculto hasta que recibe el foco, que permite a quien navega con teclado o lector de pantalla evitar la cabecera repetida en cada página y llegar directamente al contenido; esto cubre el criterio WCAG 2.4.1 (*Evitar bloques*). El flujo de reserva se divide en pasos cortos para exigir los mínimos clics posibles y no abrumar.

Comprensible: estructura y ayuda. El marcado es HTML semántico (encabezados jerárquicos, `nav`, `main`, `footer`), con el idioma declarado (`lang=.es`) para que los lectores de pantalla lo pronuncien correctamente, atributos ARIA donde el componente lo requiere y una etiqueta asociada a cada campo de formulario. La validación de los datos es inmediata y con mensajes claros, y la reserva guiada por pasos reduce la carga cognitiva, algo especialmente valioso para usuarios poco habituados a la tecnología.

Robusto: preferencias del usuario y zoom. La maquetación usa unidades relativas (`rem`, `clamp`) que permiten ampliar el tamaño de letra del navegador sin que la interfaz se rompa, y respeta la preferencia del sistema `prefers-reduced-motion`, desactivando las animaciones para quienes sufren mareo con el movimiento (problemas vestibulares). El modo claro/oscuro, además de comodidad, ofrece una alternativa a personas sensibles al brillo.

Limitación honesta. La accesibilidad se ha trabajado por diseño y se ha verificado el contraste de forma manual, pero no se ha pasado todavía una auditoría automática completa (por ejemplo, *Lighthouse* o *axe*) ni se ha probado con usuarios reales de lector de pantalla. Documentar esa auditoría y realizar pruebas con

usuarios es la evolución natural de este apartado, ya recogida entre las líneas futuras de calidad.

3.2.18 Sincronización de citas: una sola fuente de verdad

Uno de los problemas más instructivos del desarrollo no fue de algoritmos, sino de *coherencia de datos* entre vistas. Al principio, la lista “Mis citas programadas” que veía el paciente vivía solo en el `localStorage` del navegador, mientras que el panel de pruebas del médico leía de la base de datos. El resultado eran incoherencias desconcertantes: citas que aparecían para el paciente pero no en el panel, cancelaciones que solo existían en un navegador, e incluso reservas antiguas con identificadores locales que nunca habían llegado al servidor.

La solución fue establecer una **única fuente de verdad**: PostgreSQL. La función `syncMisCitas()` de `reserva.js` sustituye la caché local por lo que realmente hay en el servidor, consultando `GET /api/citas/mias` para el paciente autenticado o `GET /api/citas/por-email` para el invitado. Esta sincronización se dispara en los momentos clave: al cargar la página de reserva, tras confirmar o cancelar una cita, al escribir el email (con *debounce*) y tras iniciar o cerrar sesión. Así, lo que ve el paciente y lo que ve el panel siempre coinciden, porque ambos derivan del mismo origen. La regla de diseño es sencilla y se defiende bien ante el tribunal: *el navegador nunca es la verdad; solo refleja la base de datos tras cada sincronización*.

3.2.19 Cuadro de mando de gestión (analítica)

Una consulta médica no es solo una agenda: es una pequeña empresa que genera datos cada día. Esos datos, si se quedan dispersos en filas de una tabla, no le dicen nada al profesional; pero agregados y representados visualmente revelan información útil para tomar decisiones: qué especialidad se demanda más, cómo se reparte la carga de trabajo, qué centro concentra más actividad o cuántas citas se cancelan. Con esa idea —entender la clínica como un negocio que se puede medir y optimizar— se incorporó un **cuadro de mando de gestión**, accesible solo para el personal interno.

La pieza clave es que toda la analítica se calcula **en la base de datos**, no en memoria. El endpoint `GET /api/estadisticas` se apoya en consultas de agregación `GROUP BY` (con `COUNT`, `JOIN`, `LEFT JOIN`, `COALESCE` para los valores nulos y las funciones de fecha `YEAR()`/`MONTH()`) que devuelven directamente los totales ya calculados. Para no traer las entidades completas a memoria, cada consulta usa una *proyección* ligera de Spring Data —una interfaz con solo los

campos necesarios (etiqueta y total)—, lo que mantiene la respuesta pequeña y la consulta eficiente. El servicio que orquesta estas consultas se marca como `@Transactional(readOnly = true)`, una señal explícita de que solo lee datos y nunca los modifica. El cálculo de indicadores derivados, como la tasa de cancelación, se hace en el servicio a partir del reparto por estado, evitando consultas redundantes.

El cuadro de mando presenta primero cuatro indicadores resumen (KPIs) y, debajo, cinco gráficos:

- **Indicadores:** total de citas, citas activas (pendientes y confirmadas), completadas y **tasa de cancelación** como aproximación al ausentismo.
- **Carga de trabajo por médico** (barras): cuántas citas gestiona cada facultativo, de mayor a menor.
- **Demanda por especialidad** (barras): las áreas más solicitadas.
- **Distribución por centro** (barras): el reparto de actividad entre ubicaciones.
- **Reparto por estado** (anillo): la proporción de confirmadas, pendientes, completadas y canceladas.
- **Evolución temporal** (línea): el volumen de citas mes a mes, para detectar tendencias.

En el frontend, los gráficos se dibujan con **Chart.js**, una librería ligera que se incorporó *vendorizada* en el propio repositorio (`js/vendor/`) en lugar de cargarse desde una CDN externa. La decisión es deliberada: el sistema no depende de una conexión a internet ajena para funcionar —coherente con la filosofía PWA y *offline first* del proyecto— y la demo ante el tribunal es reproducible aunque no haya red. La página respeta el modo claro/oscuro recalculando los colores al cambiar de tema, y **degrada con elegancia**: si quien la abre no ha iniciado sesión como personal autorizado, en lugar de un error muestra un aviso claro invitando a identificarse.

El acceso está restringido en `SecurityConfig` a los roles `MEDICO` y `ADMIN`: las analíticas de negocio son una herramienta interna y no deben ser visibles para un paciente ni para un usuario anónimo. Esta restricción se verificó en vivo —una petición sin token recibe **403 Forbidden**, mientras que con el token de un médico el endpoint devuelve los datos agregados—, lo que conecta este módulo directamente con la política de autorización por rol descrita más adelante. En conjunto, el cuadro de mando demuestra la competencia de *sistemas de gestión empresarial*: convertir los datos operativos del día a día en información de gestión accionable.

3.2.20 Seguridad y RGPD

La seguridad no se añadió al final, se diseñó desde el principio, porque manejar datos de salud obliga a ello. El acceso está gobernado por roles (PACIENTE, MEDICO, ADMIN) declarados en `SecurityConfig`: cada ruta exige el rol mínimo necesario, de modo que un paciente no puede asomarse a la agenda del médico ni un usuario anónimo crear citas en nombre de otro. Sobre esa base se aplican las medidas concretas de protección de datos:

- Contraseñas con `BCryptPasswordEncoder(12)`.
- CORS configurado para orígenes de desarrollo y producción.
- Política de privacidad en `privacidad.html` y checkbox de aceptación en el formulario de reserva.
- Secretos (JWT_SECRET, Twilio) en `.env`, no en el repositorio.
- **Análisis de vulnerabilidades:** OWASP `dependency-check` configurado en `pom.xml`, que hace fallar el build con $CVSS \geq 7$.

3.2.21 Despliegue

Uno de los objetivos era que el sistema completo se pudiera levantar sin instalar nada manualmente, ni siquiera por alguien sin experiencia previa. Por eso todo el despliegue se reduce a un único comando, que construye las imágenes y arranca los contenedores en el orden correcto:

```
1 docker compose up -d --build
```

Esto levanta tres servicios coordinados: `postgres` (la base de datos), `backend` en el puerto 8080 (la API Spring Boot) y `frontend` en el puerto 80 (nginx sirviendo la web y haciendo de proxy de `/api`). El `docker-compose` define dependencias y comprobaciones de salud, de modo que el backend no se da por listo hasta que la base de datos responde. El artefacto del backend es un **JAR de Spring Boot con servidor embebido** (generado por `spring-boot-maven-plugin`), el esquema de la base de datos se versiona con Flyway —que aplica las migraciones pendientes en el primer arranque— y la configuración se separa por perfiles (`application-postgres.yml` y `application-mysql.yml`), existiendo además un perfil opcional de MySQL con `-profile mysql`. La ventaja práctica es enorme de cara a la defensa: el entorno del tribunal será idéntico al de desarrollo, eliminando el clásico “en mi máquina funciona”.

Dominio e identidad de marca. De cara al salto a producción se ha registrado el dominio `dragramonte.com`, una marca personal corta, profesional y fácil de dictar por teléfono (frente a alternativas más largas que se descartaron). La aplicación ya está preparada para ese dominio: los pies de página, la página de contacto, las etiquetas `Open Graph` y la política de CORS del backend apuntan a `dragramonte.com`, y el correo de contacto utiliza la propia marca (`contacto@dragramonte.com`). El despliegue real bajo ese dominio —con un certificado HTTPS y alojamiento en la nube— queda recogido entre las líneas de trabajo futuras; la migración de identidad, en cambio, ya está hecha en el código.

3.2.22 Sostenibilidad y eficiencia (green computing)

La sostenibilidad de este proyecto no es una etiqueta añadida al final, sino una consecuencia directa de las decisiones de diseño. Un software es sostenible cuando consume los recursos justos —energía, ancho de banda, hardware y, en última instancia, dinero— para hacer su trabajo, y cuando además *sustituye* procesos físicos más costosos. Dr. Agramonte actúa en los dos frentes: reduce el gasto material de la consulta y se ha construido para gastar poco al ejecutarse.

Digitalización y ahorro de papel. El primer impacto es el más evidente: la aplicación elimina la agenda de papel y los apuntes manuales que hoy usan muchas consultas pequeñas. Las citas, sus cambios y su historial viven en la base de datos, y los avisos llegan por canales digitales (SMS o WhatsApp vía Twilio) en lugar de recordatorios impresos o llamadas que consumen tiempo y, a veces, desplazamientos. Menos papel significa menos impresión, menos almacenamiento físico y menos residuos; y al evitar visitas o llamadas innecesarias para gestionar una cita, se reduce también el desplazamiento del paciente, con su correspondiente huella. Es la traducción concreta del objetivo de desarrollo sostenible **ODS 12** (producción y consumo responsables) a una consulta médica.

Software eficiente, menos energía. La eficiencia técnica es, en la práctica, eficiencia energética: cada ciclo de CPU y cada byte transferido que se ahorran se traducen en menos consumo, tanto en el servidor como en los miles de dispositivos de los pacientes. Varias decisiones del proyecto van en esa dirección:

- **Frontend sin framework.** Prescindir de React o Vue evita arrastrar un `node_modules` de cientos de megas y enviar grandes paquetes de JavaScript al navegador. La web carga más rápido y exige menos CPU al cliente, lo que en un parque grande de dispositivos no es despreciable.

- **Recursos vendorizados.** Servir Chart.js desde el propio dominio en lugar de una CDN externa reduce peticiones de red a terceros y dependencias innecesarias.
- **Cálculo en la base de datos.** El cuadro de mando agrega los datos con consultas `GROUP BY` en PostgreSQL en lugar de traer todas las filas a memoria y procesarlas en la aplicación. Mover el cálculo a donde están los datos transfiere menos información y gasta menos memoria y CPU en el backend.
- **Una sola base de datos relacional.** No hay un clúster de servicios (Redis, Mongo) corriendo y consumiendo energía en reposo: un único PostgreSQL cubre las necesidades reales del volumen de una consulta.
- **Autenticación *stateless*.** El token JWT evita guardar sesiones en el servidor, reduciendo el estado que hay que almacenar y mantener.

Infraestructura ligera y escalable a la baja. El backend se empaqueta con un Dockerfile *multi-stage*, de modo que la imagen final solo contiene el JRE y el JAR, sin las herramientas de compilación: imágenes más pequeñas significan menos disco, descargas más rápidas y menos energía en cada despliegue. El sistema completo cabe holgadamente en un servidor modesto (un VPS pequeño basta para una consulta), y los contenedores pueden apagarse cuando no se usan. Frente a la tendencia de sobredimensionar (*just in case*), aquí se dimensiona para la necesidad real (*just enough*), que es la forma más directa de **green computing**: no encender lo que no hace falta.

Sostenibilidad del propio software. Un sistema también es sostenible si dura. La reproducibilidad con Docker y Flyway evita reconstrucciones manuales propensas a error; el análisis de vulnerabilidades con OWASP *dependency-check* mantiene las dependencias sanas en el tiempo; y un código legible, sin capas innecesarias, es más fácil de mantener durante años por otra persona. Un software que se mantiene vivo y seguro no hay que reescribirlo desde cero cada poco, lo que es una forma de no malgastar esfuerzo ni recursos.

Limitación honesta. No se ha realizado una medición formal de la huella de carbono ni del consumo energético real (con herramientas como auditorías de *Lighthouse* o medidores de consumo del contenedor); las afirmaciones anteriores son cualitativas y se apoyan en las decisiones de arquitectura, no en métricas instrumentadas. Cuantificar ese ahorro —por ejemplo, comparar el consumo del

frontend frente a una versión con framework— es una línea de mejora natural y coherente con el resto del proyecto.

3.2.23 Planificación temporal

El desarrollo se organizó en fases encadenadas a lo largo de cuatro meses, partiendo del análisis y el diseño de datos antes de escribir el grueso del backend, y dejando la redacción de la memoria como una tarea transversal que acompañó a todo el proyecto. El diagrama de Gantt de la figura siguiente resume esa planificación por hitos; en la práctica algunas fases se solaparon (por ejemplo, las pruebas se fueron escribiendo a la vez que avanzaban backend y frontend), algo habitual y deseable en un desarrollo iterativo.

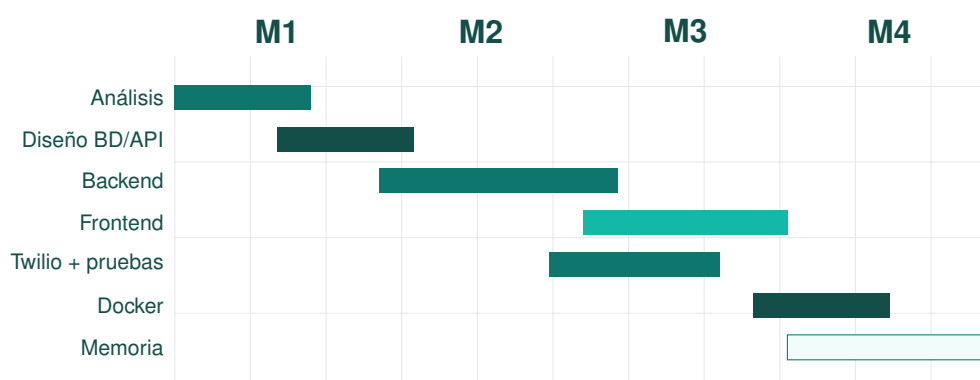


Figura 3.6: Diagrama de Gantt por hitos (M1–M4).

3.2.24 Pruebas y validación

La estrategia de pruebas se centró en los **caminos críticos**, aquellos en los que un fallo tendría consecuencias reales: la no duplicación de reservas, el respeto de los permisos por rol y la validez del token de autenticación. La filosofía no fue “probarlo todo” de forma superficial, sino probar bien lo que importa, combinando tres niveles —unitario, de seguridad e integración— para cubrir el comportamiento desde distintos ángulos. El proyecto incorpora una batería de pruebas automatizadas, ejecutable con `mvn test` desde `backend/`:

- **Unitarias (caja blanca):** `CitaServiceTest` (reserva sobre franja libre confirma y bloquea el horario; franja ocupada → 409 sin persistir; cancelación por no propietario → 403; re-cancelación → 409). `JwtProviderTest` (generación, validación y expiración del token firmado).
- **Seguridad / RBAC (caja negra, WebMvc):** `CitaControllerWebMvcTest` importa la `SecurityConfig` real: rol MEDICO sobre rutas de paciente →

403; acceso anónimo bloqueado; rol PACIENTE → 201.

- **Integración end-to-end (Testcontainers + PostgreSQL real):** ReservaPublicaIntegrationTest: dos reservas sobre la misma franja → la segunda 409; reserva pública persistida y consultable por email.
- **Análisis de vulnerabilidades:** OWASP dependency-check (mvn org.owasp:dependency-check-maven:3.5.0) → 0 vulnerabilidades.
- **Manuales:** compilación Maven, arranque Docker Compose y health check; flujo registro/login → reservar → mis citas → cancelar; parámetro ?servicio=; validación de formularios (email, teléfono español).

Tabla 3.4: Matriz de trazabilidad requisito ↔ prueba (RTM)

Requisito	Prueba	Tipo	Resultado
No doble reserva concurrente	ReservaPublicaIntegrationTest	Integración	409 ✓
RBAC / menor privilegio	CitaControllerWebMvcTest	Seguridad	403 ✓
JWT firmado válido	JwtProviderTest	Unitaria	✓
Solo el dueño cancela	CitaServiceTest	Unitaria	403 ✓
No re-cancelar	CitaServiceTest	Unitaria	409 ✓

Mejoras futuras de calidad. Informe de cobertura formal con **JaCoCo** ($\geq 80\%$ medido), pruebas E2E (Playwright/Cypress), auditoría **Lighthouse** documentada y escenario de alta disponibilidad (réplicas/failover), hoy contemplado como diseño y no ejecutado en esta infraestructura.

Capítulo 4:

Conclusiones

Se ha entregado una aplicación funcional y desplegable que responde al problema de gestión de citas, con arquitectura clara, código mantenible y **pruebas automatizadas** que cubren los caminos críticos (409 por doble reserva, 403 por rol, JWT firmado, cancelación). Los objetivos técnicos del repositorio se cumplen en PostgreSQL, Spring Boot, frontend PWA y Twilio integrado en Java.

Cumplimiento de los objetivos. Retomando los ocho objetivos específicos planteados al inicio, el balance es el siguiente:

1. *Modelo de datos en PostgreSQL con Flyway.* **Cumplido:** seis tablas, migraciones V1–V6 y perfiles `postgres/mysql`.
2. *API REST con Spring Boot, JWT y roles.* **Cumplido:** controladores por recurso, autenticación JWT y autorización por rol en `SecurityConfig`.
3. *Integridad de reservas con `SELECT FOR UPDATE`.* **Cumplido y verificado:** la prueba de integración confirma que la segunda reserva concurrente recibe 409.
4. *Frontend responsive, PWA y reserva accesible.* **Cumplido:** reserva por pasos, modo oscuro, selección de centro y service worker.
5. *Notificaciones por Twilio con recordatorio programado.* **Cumplido:** avisos a médico y paciente y recordatorio a ~24 h vía `@Scheduled`.
6. *Despliegue reproducible con Docker Compose.* **Cumplido:** un único comando levanta base de datos, backend y frontend.
7. *Validación de la calidad.* **Cumplido parcialmente:** pruebas unitarias, de seguridad e integración más OWASP `dependency-check`; queda pendiente medir la cobertura con JaCoCo y añadir pruebas E2E.

8. *Cuadro de mando de gestión (SGE)*. **Cumplido:** endpoint `/api/estadisticas` con agregaciones `GROUP BY`, restringido por rol y representado con Chart.js (carga por médico, demanda por especialidad, reparto por centro y estado, evolución temporal y tasa de cancelación).

Limitaciones honestas: la cobertura no está medida con JaCoCo (se valida cualitativamente por ramas críticas), el panel médico no expone API de historial, no hay refresh token ni escenario de réplicas/failover. Son líneas de evolución natural del TFG, no carencias del alcance entregado.

Líneas de trabajo futuras. El proyecto está pensado para seguir creciendo más allá de la entrega. Las evoluciones más coherentes con lo ya construido son:

- **Panel clínico multi-centro:** con la agenda por centro ya implementada (horarios y citas asociados a su centro, disponibilidad filtrada), el siguiente paso sería un panel médico visual que conmute entre ubicaciones y muestre la ocupación de cada centro de un vistazo.
- **Recordatorios con confirmación previa:** permitir que el paciente confirme o cancele desde el propio aviso, reduciendo ausencias.
- **Historial de cambios de la cita:** que el paciente vea reprogramaciones y cancelaciones.
- **Página de ayuda / preguntas frecuentes:** apoyo específico para pacientes mayores o poco digitales.
- **Calidad:** informe de cobertura con JaCoCo, pruebas E2E (Playwright) y auditoría de accesibilidad documentada.
- **Seguridad y escalado:** *refresh token*, despliegue en la nube bajo el dominio ya registrado `dragramonte.com` con certificado HTTPS, y réplicas de base de datos.
- **Historial clínico:** API y panel clínico reales, con almacenamiento documental flexible por especialidad (p. ej. MongoDB), avanzando hacia una persistencia políglota.

Aprendizajes: el proyecto ha consolidado competencias de los módulos de DAM (acceso a datos, programación de servicios, interfaces, sistemas de gestión empresarial y empresa e iniciativa emprendedora) en un caso real, integrando seguridad, concurrencia y despliegue.

Reflexión: la coherencia entre memoria, código y demo oral es tan importante como la funcionalidad; este documento describe la versión real del sistema a junio de 2026.

Agradecimientos

Este proyecto no es solo horas frente a una pantalla: es el reflejo de conversaciones, experiencias y realidades observadas durante años.

A mi **familia**, por el apoyo y la paciencia durante todo el desarrollo, y por ser quienes me enseñaron de cerca lo que significa cuidar de los demás.

A mis **amigos y conocidos del entorno sanitario**, que compartieron sus experiencias y sus días difíciles y, sin pretenderlo, inspiraron el problema que este proyecto intenta aliviar. Esta herramienta es, en el fondo, para ellos.

A mis **profesores del ciclo**, por darme las herramientas necesarias —técnicas y de criterio— para convertir una idea observada en la realidad en una aplicación funcional, y por ayudarme a entender que un proyecto pequeño y sólido vale más que una idea enorme a medias.

Y a mis **compañeras y compañeros de DAM**, que probaron la aplicación sin filtros y dieron un *feedback* honesto que mejoró el resultado.

Bibliografía

Bibliografía

- [1] Spring. (2024). *Spring Boot 3.5 reference documentation*. <https://spring.io/projects/spring-boot>
- [2] Spring. (2024). *Spring Security reference*. <https://docs.spring.io/spring-security/reference/>
- [3] Parlamento Europeo y Consejo de la Unión Europea. (2016). *Reglamento (UE) 2016/679, de 27 de abril de 2016, relativo a la protección de las personas físicas (RGPD)*. Diario Oficial de la Unión Europea. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- [4] Jefatura del Estado. (2002). *Ley 41/2002, de 14 de noviembre, básica reguladora de la autonomía del paciente y de derechos y obligaciones en materia de información y documentación clínica*. BOE núm. 274. <https://www.boe.es/eli/es/l/2002/11/14/41>
- [5] World Wide Web Consortium. (2021). *Web Content Accessibility Guidelines (WCAG) 2.1*. <https://www.w3.org/WAI/WCAG21/quickref/>
- [6] Docker, Inc. (s.f.). *Docker Compose documentation*. Recuperado en junio de 2026, de <https://docs.docker.com/compose/>
- [7] Twilio. (s.f.). *Messaging API documentation*. Recuperado en junio de 2026, de <https://www.twilio.com/docs/messaging>
- [8] Redgate. (s.f.). *Flyway documentation*. Recuperado en junio de 2026, de <https://documentation.red-gate.com/fd>
- [9] Testcontainers. (s.f.). *Testcontainers for Java*. Recuperado en junio de 2026, de <https://java.testcontainers.org/>
- [10] Doctoralia. (s.f.). *Plataforma para profesionales*. Recuperado en junio de 2026, de <https://www.doctoralia.es>

Anexos

Anexo A. Checklist de cumplimiento (rúbricas del módulo)

Checklist de cumplimiento — Módulo de Proyecto

Proceso (25 %) + contenido escrito (40 %) + defensa (35 %)

Memoria alineada con el repositorio (mayo 2026). Marcar al entregar.

Criterio	Mem.	Demo	Notas
A. Proceso (25 %)			
Seguimiento con tutor documentado	☐	—	Anexar evidencias
Gantt / hitos coherentes con el calendario real	✓	—	Cap. planificación
Coherencia memoria ↔ código	✓	✓	Sin Mongo/Redis/Node en memoria
B. Contenido escrito (40 %)			
Estructura guía (justificación, objetivos, sector 5.1, desarrollo 5.2, conclusiones)	✓	—	Orden oficial
PDF, márgenes 3 cm, fuente, interlineado 1,15	✓	—	Falta confirmar 35–65 pág.
Diagramas TikZ (paleta teal CSS)	✓	—	Cap. desarrollo
Referencias APA	✓	—	Bibliografía en APA
Anexos (checklist, manual, capturas)	✓	—	Faltan insertar capturas
C. Defensa (35 %)			
Demo: login → reservar → cancelar	☐	☐	<code>docker compose up</code>
Demo servicio preseleccionado + modo oscuro	☐	☐	
Plan B (capturas / vídeo)	☐	☐	
Twilio en sandbox (opcional)	☐	☐	
D. Implementación verificada en repo			
PostgreSQL + Flyway + Spring Boot + JWT	✓	✓	
<code>SELECT FOR UPDATE</code> + citas	✓	✓	
Frontend PWA + reserva + servicios URL	✓	✓	
Twilio Java (médico, paciente, recordatorio)	✓	☐	Requiere <code>.env</code>
Panel médico API historial	☐	☐	Solo demo estática
Tests automatizados JUnit + Testcontainers	✓	✓	E2E (Playwright) pendiente

Criterio	Mem.	Demo	Notas
OWASP dependency-check (CVSS $\geq$ 7)	✓	☐	pom.xml

Anexo B. Manual de usuario (resumen)

1. **Registro / acceso:** desde `login.html`, crear cuenta (rol PACIENTE) o iniciar sesión. El sistema devuelve un token JWT que el navegador guarda para las peticiones protegidas.
2. **Elegir servicio (opcional):** en `servicios.html`, pulsar un servicio abre la reserva con el tipo de consulta preseleccionado (`reservar.html?servicio=...`).
3. **Reservar:** en `reservar.html` seguir los pasos centro → calendario → hora → datos → confirmación, aceptando la política de privacidad.
4. **Mis citas:** consultar las citas propias y su estado; el paciente recibe confirmación (y recordatorio ~24 h antes) por Twilio si tiene teléfono.
5. **Cancelar:** desde “Mis citas”, cancelar libera la franja y notifica al médico.
6. **Tema claro/oscuro:** el botón luna/sol alterna el modo y se recuerda la preferencia.

Anexo C. Capturas de pantalla

Incluir aquí las capturas de la demo (inicio, servicios, flujo de reserva, mis citas y modo oscuro). Cada captura debe ir numerada y con su leyenda. Ejemplo de inclusión:

```
\begin{figure}[H]
  \centering
  \includegraphics[width=0.8\textwidth]{capturas/reserva-paso1.png}
  \caption{Primer paso del flujo de reserva: selección de centro.}
\end{figure}
```